

Identity Is the New Perimeter

Why attackers increasingly prefer **logging in** over breaking in

CORE THESIS

When the credential, token, or workload identity is trusted, the attacker can inherit the same paths the user or service was meant to use.

That changes the defensive question from “**Did something cross the perimeter?**” to “**Should this identity be doing this, from here, right now?**”

Scope

Cloud identity | stolen credentials | session tokens | OAuth/service identities | SOC detection | remediation

[7-page executive research brief](#)

The perimeter did not disappear. Trust moved.

Identity is now a primary control plane for cloud and SaaS access. Unit 42 reports that identity weaknesses played a material role in almost 90% of its 2025 investigations. Microsoft says 97% of identity attacks it observed were password-spray attacks, while its systems analyzed about 38 million identity-risk detections on an average day.

~90%

of Unit 42 investigations: identity weaknesses played a material role

Unit 42 2026

97%

of Microsoft identity attacks: password spray

Microsoft 2025

38M

identity-risk detections analyzed on an average day

Microsoft 2025

Identity attack composition reported by Microsoft (2025)

97% password spray

3% other

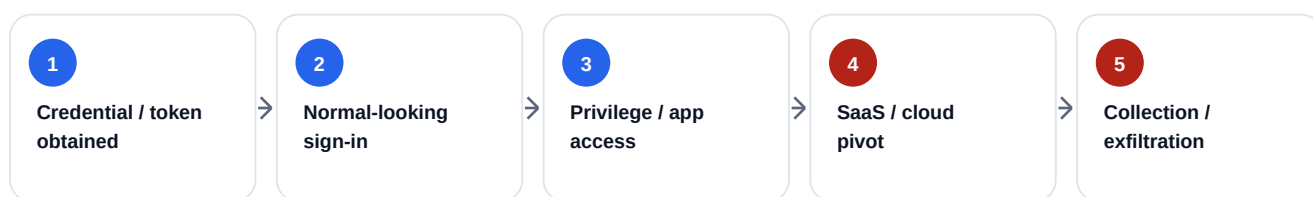
Different datasets answer different questions: Unit 42 describes contributing factors in incident-response cases; Microsoft describes identity attack telemetry. They should not be treated as the same denominator.

Why this matters: a valid identity can enter through the front door. It can make API calls, open SaaS data, access mail, request cloud tokens, and move through trusted integrations. That reduces the value of perimeter-only thinking and increases the value of strong authentication, least privilege, token controls, identity telemetry, and continuous verification.

Bottom line: the attacker does not always need a zero-day. Sometimes the highest-leverage exploit is a credential or token that the environment already trusts.

Why “valid account” attacks are difficult to spot

MITRE ATT&CK; maps **Valid Accounts (T1078)** across Initial Access, Persistence, Privilege Escalation and Defense Evasion. The reason is simple: legitimate credentials let an adversary use legitimate interfaces.



Detection challenge: the transport can be encrypted, the application can be legitimate, and the account can be real. The anomaly may exist only in context: device, location, ASN, token age, consent, privilege, workload, or volume.

FOUR IDENTITIES DEFENDERS MUST TREAT AS SECURITY PRINCIPALS

Human accounts

Employees, admins, contractors; exposed by phishing, password reuse, help-desk manipulation.

Sessions & tokens

Bearer-style proof that authentication already happened; theft can bypass a password prompt.

OAuth / app grants

Permissions delegated to apps; a malicious or over-privileged grant can persist beyond a password reset.

Non-human identities

Service accounts, API keys, workload identities and CI/CD secrets; often high privilege and low visibility.

Snowflake campaign: the platform was not the entry point

In 2024, Mandiant tracked UNC5537 compromising Snowflake customer instances using **stolen customer credentials**. Mandiant said it found no evidence that the activity originated from a breach of Snowflake's enterprise environment. In the incidents it responded to, access was traced to compromised customer credentials.

WHAT HAPPENED



~165

potentially exposed organizations notified by Mandiant and Snowflake

[Google Cloud / Mandiant](#)

April 2024: Mandiant investigates database records traced to a victim Snowflake instance.

May 22, 2024: broader campaign identified; Mandiant and Snowflake begin notifying potential victims.

WHY IT MATTERS

- **No perimeter exploit was required.** The attacker could use customer-owned credentials against an internet-facing cloud service.
- **Infostealers turn endpoints into identity breaches.** Credentials stolen earlier can be replayed later against SaaS platforms.
- **Cloud blast radius follows permissions.** A data-platform identity can expose far more than one endpoint if access is broad.

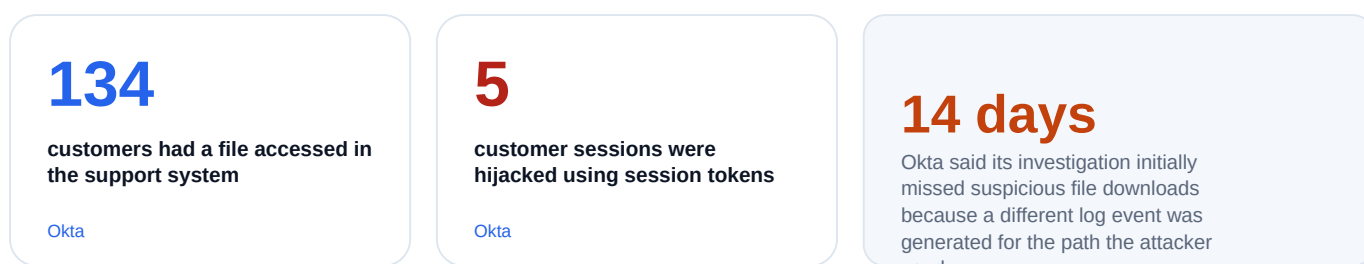
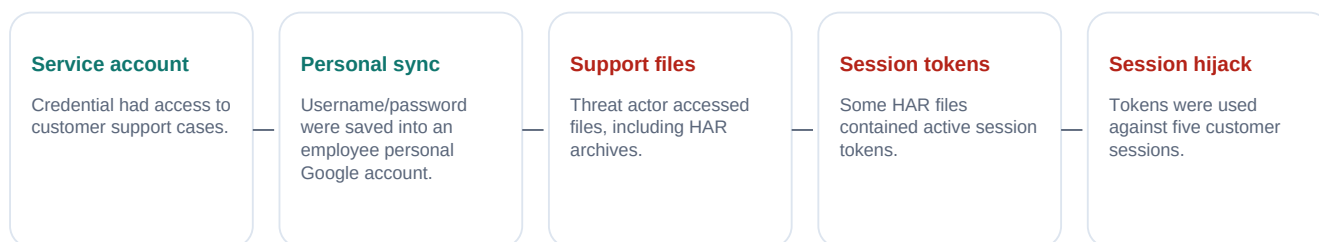
Defender takeaway: require phishing-resistant MFA where supported, eliminate stale credentials, constrain network/session context, and alert on unusual bulk data access after a first-time or high-risk sign-in.

[Primary source: Mandiant / Google Cloud - UNC5537 Targets Snowflake Customer Instances](#)

Okta support incident: identity can be stolen after login

The 2023 Okta support-system incident shows why protecting passwords alone is not enough. Okta reported that an attacker accessed support files tied to 134 customers. Some uploaded HAR files contained **session tokens**, and the attacker used such tokens to hijack legitimate Okta sessions of five customers.

ROOT-CAUSE CHAIN REPORTED BY OKTA



THE DEEPER LESSON

A session token is effectively a short-lived identity artifact. If it is bearer-based and still valid, stealing it can let an attacker act as a user **after** authentication. Password resets alone may therefore be insufficient unless sessions/tokens are revoked or constrained.

Token defense stack

- Shorter / risk-aware session lifetime
- Reauthentication for sensitive actions
- Token/session binding where supported
- Revoke sessions during incident response
- Detect location/device/network changes

[Primary source: Okta - Root Cause and Remediation](#)

[Technical reference: Microsoft - Protecting Tokens](#)

Build controls around trust, not just traffic

The goal is not “more MFA” in isolation. It is a layered identity control system that assumes passwords, devices, tokens, or third-party integrations can eventually be compromised.

1

1. Phishing-resistant authentication

FIDO/WebAuthn or equivalent strong authentication for privileged and sensitive access.

Blocks many credential-phishing and password-replay paths.

2

2. Conditional access + reauthentication

Use sign-in risk, device state, location/network, and action sensitivity.

A correct password should not automatically equal trusted context.

3

3. Least privilege + privilege-on-demand

Keep standing admin rights and broad SaaS/database permissions to a minimum.

Reduces blast radius after a valid-account compromise.

4

4. Token + session controls

Shorter sessions where practical, revoke on risk, bind tokens/session context where supported.

Limits post-authentication replay and persistence.

5

5. Non-human identity hygiene

Inventory service accounts, API keys, OAuth apps and workload identities; rotate and scope secrets.

Protects the identities that do not have a human watching them.

6

6. Identity-aware detection

Correlate IdP, endpoint, cloud, SaaS and data-access telemetry.

Detect “valid but abnormal” behavior instead of only malware.

[CISA: More than a Password - MFA and phishing-resistant FIDO/WebAuthn](#)

[CISA: Enhanced Visibility and Hardening Guidance - session duration, RBAC, least privilege](#)

Detect the identity behaving badly, not only the malware



High-value alerts: first-time country/ASN + privileged action; impossible or improbable travel; dormant account use; new OAuth consent; service-account interactive login; session reuse after password reset; unusual bulk download; sudden role escalation.

PRIMARY / TECHNICAL SOURCES - CLICK TO OPEN

Unit 42 - 2026 Global Incident Response Report	OPEN SOURCE >
Microsoft - Digital Defense Report 2025	OPEN SOURCE >
Mandiant / Google Cloud - UNC5537 and Snowflake	OPEN SOURCE >
Okta - Support System Root Cause & Remediation	OPEN SOURCE >
MITRE ATT&CK - Valid Accounts T1078	OPEN SOURCE >
MITRE ATT&CK - Steal Application Access Token T1528	OPEN SOURCE >
CISA - More than a Password / phishing-resistant MFA	OPEN SOURCE >
Microsoft Learn - Protecting Tokens in Entra ID	OPEN SOURCE >

Final takeaway: If an organization trusts identity to open cloud, SaaS and data-plane doors, identity must be monitored like a network perimeter: continuously, contextually, and with the assumption that trust artifacts can be stolen.